

OWASP ZAP

Ferramenta de segurança para análise de aplicações Web.

O que é

ZAP é um proxy de segurança open source usado para inspecionar tráfego e apoiar testes de aplicações Web.

Uso seguro

Comece com ambientes autorizados. Passive Scan observa tráfego; Active Scan envia ataques e não deve ser usado sem autorização explícita.

QA no pipeline

ZAP pode apoiar DAST automatizado em ambientes controlados, com critérios para triagem de falsos positivos.

Quando usar

Use este conhecimento quando o risco, a arquitetura ou a etapa do ciclo de desenvolvimento exigir validação específica. Antes de aplicar, confirme objetivo, ambiente, dados necessários e evidências esperadas.

Como o QA aplica na prática

Comece pelo comportamento ou risco que precisa ser validado, prepare dados e ambiente, execute a técnica ou ferramenta de forma reproduzível e registre evidências que permitam explicar o resultado ao time.

Boas práticas

Priorize cenários de maior impacto, mantenha dados e ambiente controlados, registre decisões importantes e revise periodicamente a abordagem para evitar cobertura redundante ou desatualizada.

Dica de QA

Relacione sempre a prática ao risco do produto e às evidências necessárias para a decisão de qualidade.

Recursos oficiais

Site oficial: <https://www.zaproxy.org/download/>